

Universidade Federal do Pará (UFPA)
Dr. Prof. Sandro Bezerra
Laboratório de Engenharia de Software
Aluno Luis Felipe Fernandes Cardoso

Relatório de Testes de Segurança

1. Introdução

O presente relatório tem como objetivo apresentar os resultados da análise de segurança realizada sobre a aplicação **acadmap.me** na data de **05/09/2025**. A avaliação buscou identificar vulnerabilidades técnicas, falhas de implementação e pontos de melhoria relacionados à segurança da aplicação.

2. Objetivos

Os testes tiveram como principais objetivos:

- Avaliar a resiliência da aplicação frente a ataques comuns descritos no **OWASP Top 10**.
- Identificar possíveis vulnerabilidades relacionadas a **injeção, autenticação, controle de acesso, exposição de dados e configuração de segurança**.
- Fornecer recomendações de mitigação para aumentar a segurança do ambiente.

3. Metodologia

A metodologia utilizada seguiu como referência as práticas do **OWASP Testing Guide** e do **PTES (Penetration Testing Execution Standard)**.
As etapas principais foram:

1. **Coleta de informações**: mapeamento de funcionalidades disponíveis na aplicação.
2. **Testes ativos e passivos**: validação de entradas do usuário, manipulação de parâmetros, análise de responses HTTP e comportamento da aplicação.
3. **Documentação dos achados**: cada vulnerabilidade identificada foi registrada com evidências técnicas, contexto e possíveis impactos.
4. **Análise crítica**: avaliação de risco considerando probabilidade de exploração e impacto no negócio.

4. Testes

4.1 Reconhecimento Passivo

Descrição: Coleta de informações sem interagir diretamente com o alvo.

kali@kali - [~] $ whois acadmap.me

Informações coletadas:

- Domain Name: acadmap.me
- Registrar: NameCheap, Inc.
- WHOIS Server whois.namecheap.com

- Creation Date: 22/07/2025
- Expiry Date: 22/07/2026
- Status: ClientTransferProhibited
- Contact: Dados do registrante protegidos (privacy service by “Withheld for Privacy ehf”)

A análise das informações coletadas no whois do domínio revela alguns pontos relevantes. O fato de o domínio ter sido criado recentemente sugere que a aplicação ainda pode estar em desenvolvimento ou em estágio inicial de operação, o que aumenta a probabilidade de existirem falhas de configuração e vulnerabilidades não tratadas. Além disso, o uso de serviço de privacidade no registro, embora seja uma boa prática para proteger os dados do responsável, dificulta a identificação do administrador legítimo em caso de incidentes de segurança, o que pode atrasar ações de resposta ou de reporte responsável. Também se observa que o registrador utilizado é a NameCheap, empresa bastante empregada em projetos menores e ambientes de teste, o que pode indicar ausência de processos maduros de governança e segurança.

Do ponto de vista de impacto, tais fatores podem levar a uma maior exposição a vulnerabilidades típicas de sistemas novos, como endpoints de teste acessíveis, credenciais padrão ou APIs abertas, além de dificultar a comunicação com os responsáveis legítimos em caso de abuso do domínio. Para mitigar esses riscos, recomenda-se confirmar se o domínio já está em ambiente de produção ou ainda em desenvolvimento, e, caso esteja exposto ao público, priorizar a aplicação de controles de segurança e um processo contínuo de gestão de vulnerabilidades. Também é recomendável manter informações administrativas seguras junto ao registrador, mesmo com a proteção de privacidade habilitada, e avaliar a implementação de DNSSEC para aumentar a resiliência do domínio frente a ataques de manipulação de registros.

4.2 Reconhecimento Ativo

Descrição: Coleta de informações interagindo diretamente com o alvo.

4.2.1 Varredura de portas e/ou serviços abertos.

kali@kali - [~] $ nmap –sS –Pn –p- acadmap.me
Executa um SYN scan (rápido e comum) ignorando os testes de ping, varrendo todas as portas

kali@kali - [~] $ nmap –sV –sC –p [80,443(portas encontradas abertas)] acadmap.me
exibe mais detalhes sobre os serviços/portas encontrados abertos

A varredura ativa evidenciou que o host analisado possui apenas as portas 80 e 443 abertas, ambas relacionadas ao serviço web em execução sobre Nginx 1.24.0 em ambiente Ubuntu. O fato de não haver outros serviços expostos, como banco de dados, SSH ou FTP, representa uma boa prática de segurança, já que reduz a superfície de ataque disponível. Além disso, a versão do servidor identificada é relativamente recente, o que diminui a probabilidade de exploração de vulnerabilidades conhecidas, e o redirecionamento automático de HTTP para HTTPS indica a adoção de um controle básico de segurança na transmissão de dados. Ainda assim, é importante monitorar continuamente a versão do Nginx e do sistema operacional, já que novas vulnerabilidades podem ser descobertas ao longo do tempo.

4.2.2 Varredura de diretórios / arquivos escondidos

kali@kali - [~] $ dirb https://acadmap.me /usr/share/wordlists/dirb/common.txt -w -o dirb_result.txt -N 403

Diretórios encontrados:

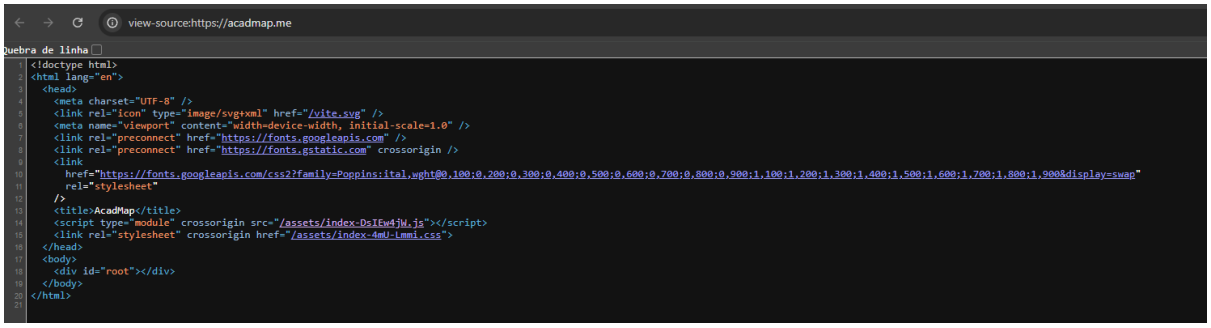
- https://acadmap.me/api
- htpps://acadmap.me/assets

Na etapa de varredura de diretórios, foram identificados os caminhos “/api” e “/assets”. A exposição de diretórios relacionados a APIs é um ponto de atenção, pois pode indicar a presença de endpoints acessíveis sem autenticação adequada, sujeitos a exploração por meio de técnicas de enumeração e fuzzing. Já o diretório “/assets”, embora costumeiramente utilizado apenas para arquivos estáticos, pode revelar informações sobre a estrutura da aplicação, bibliotecas utilizadas e versões de frameworks, dados que podem ser úteis a um atacante no planejamento de um ataque direcionado.

Do ponto de vista de impacto, a presença de diretórios acessíveis amplia a superfície de ataque, principalmente se a API permitir operações críticas ou manipulação de dados sensíveis. O risco associado pode variar de baixo a alto, dependendo do nível de proteção aplicado a esses endpoints e da exposição de informações adicionais.

Recomenda-se manter um processo de **hardening contínuo** do servidor, garantindo a atualização constante do Nginx e do Ubuntu, além de revisar periodicamente os diretórios expostos, restringindo o acesso público somente ao que for estritamente necessário. Para o caso específico da API, é fundamental validar a necessidade de autenticação, aplicar mecanismos de rate limiting contra brute force e realizar testes de segurança adicionais (como fuzzing e análise de permissões) para verificar se não há falhas de autorização ou de exposição indevida de dados.

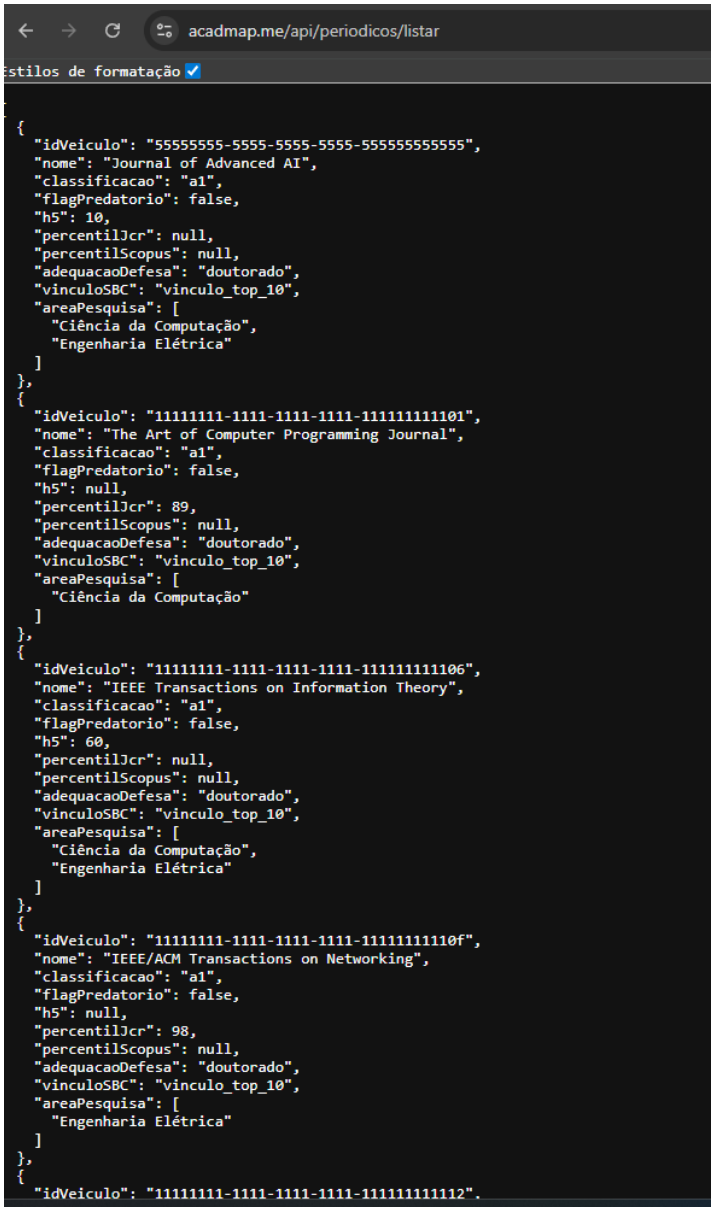
Acessando o arquivo .js a partir do código fonte da página foi possível encontrar alguns arquivos escondidos:





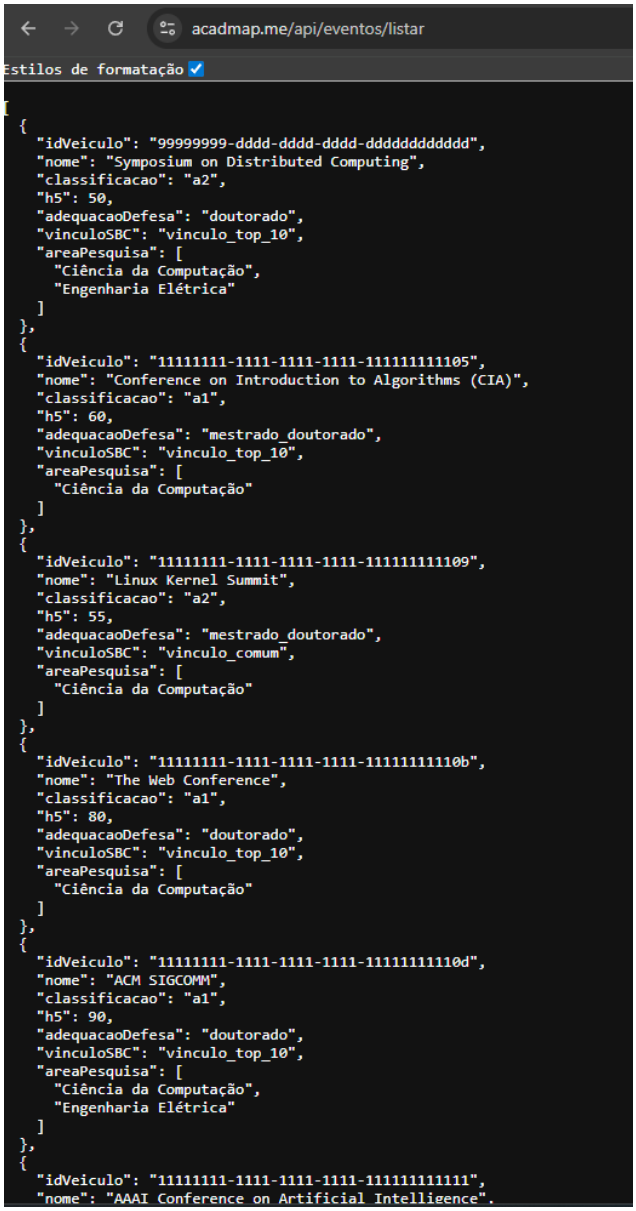
Diretórios/arquivos encontrados:

acadmap.me/api/periodicos/listar




```
[
  {
    "idVeiculo": "55555555-5555-5555-5555-555555555555",
    "nome": "Journal of Advanced AI",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": 10,
    "percentilJcr": null,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111101",
    "nome": "The Art of Computer Programming Journal",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": null,
    "percentilJcr": 89,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111106",
    "nome": "IEEE Transactions on Information Theory",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": 60,
    "percentilJcr": null,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-11111111110f",
    "nome": "IEEE/ACM Transactions on Networking",
    "classificacao": "a1",
    "flagPredatorio": false,
    "h5": null,
    "percentilJcr": 98,
    "percentilScopus": null,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111112",
```

acadmap.me/api/eventos/listar



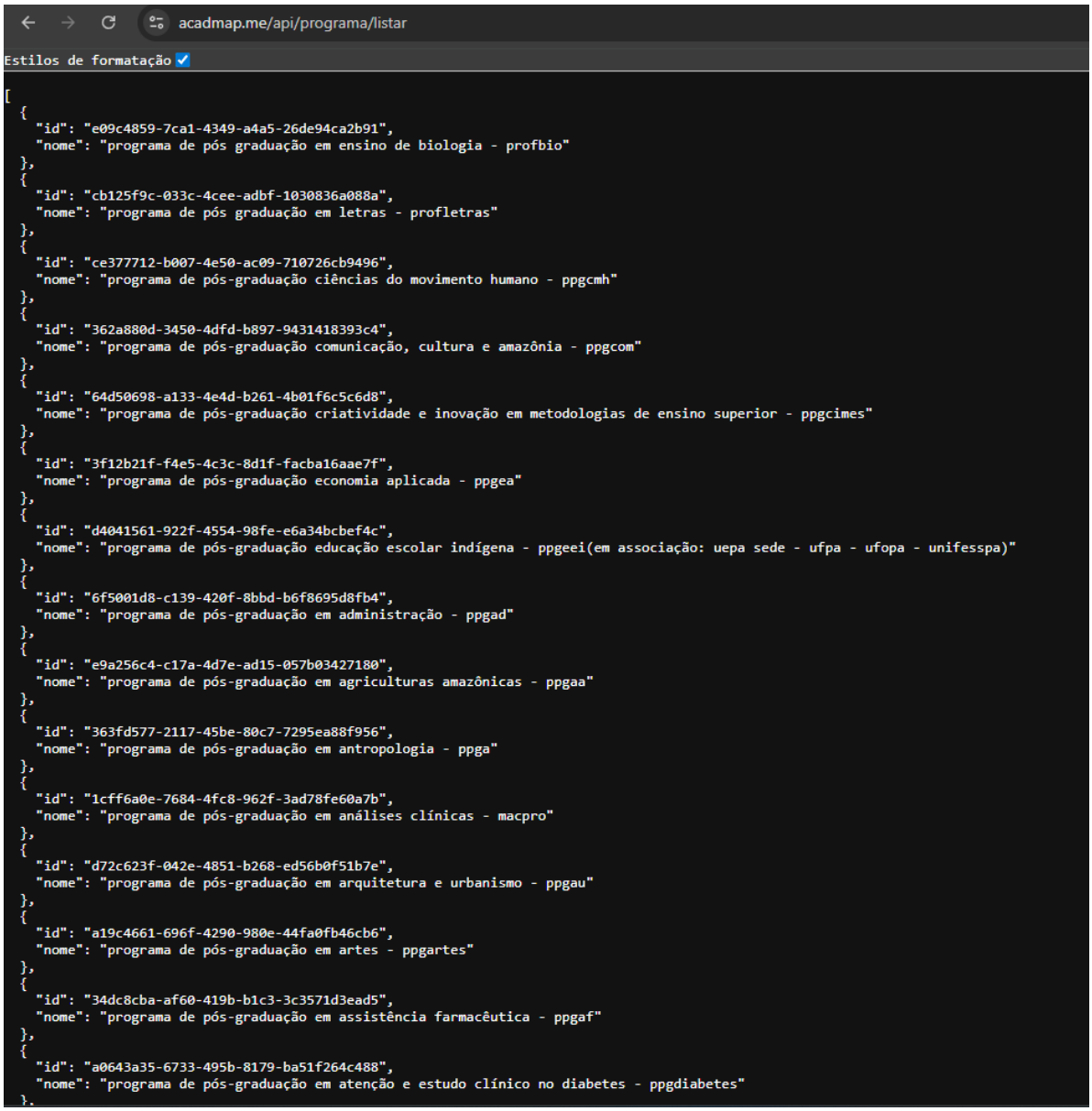

```
[
  {
    "idVeiculo": "99999999-dddd-dddd-dddd-dddddddddddd",
    "nome": "Symposium on Distributed Computing",
    "classificacao": "a2",
    "h5": 50,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111105",
    "nome": "Conference on Introduction to Algorithms (CIA)",
    "classificacao": "a1",
    "h5": 60,
    "adequacaoDefesa": "mestrado_doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111109",
    "nome": "Linux Kernel Summit",
    "classificacao": "a2",
    "h5": 55,
    "adequacaoDefesa": "mestrado_doutorado",
    "vinculoSBC": "vinculo_comum",
    "areaPesquisa": [
      "Ciência da Computação"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-11111111110b",
    "nome": "The Web Conference",
    "classificacao": "a1",
    "h5": 80,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-11111111110d",
    "nome": "ACM SIGCOMM",
    "classificacao": "a1",
    "h5": 90,
    "adequacaoDefesa": "doutorado",
    "vinculoSBC": "vinculo_top_10",
    "areaPesquisa": [
      "Ciência da Computação",
      "Engenharia Elétrica"
    ]
  },
  {
    "idVeiculo": "11111111-1111-1111-1111-111111111111",
    "nome": "AAAI Conference on Artificial Intelligence",
```

acadmap.me/api/areas/listar

Estilos de formatação ☑


```
[
  {
    "id": "879c8feb-8ea8-454c-a52b-953026b4ab00",
    "nome": "Administração"
  },
  {
    "id": "80215737-5f41-4061-b503-0214080400e1",
    "nome": "Agronomia"
  },
  {
    "id": "1231356c-6a1c-41e3-807f-29973dcd8da0",
    "nome": "Antropologia e Arqueologia"
  },
  {
    "id": "8c7f06f4-b02f-420a-8ee7-0e6c73b731b8",
    "nome": "Arquitetura e Urbanismo"
  },
  {
    "id": "79fa85ab-398c-47dd-af2a-cd027a2b0ead",
    "nome": "Artes"
  },
  {
    "id": "1ba69f30-6c97-4683-b6af-1ec63ba41f29",
    "nome": "Astronomia"
  },
  {
    "id": "a6c5a583-59fb-4724-89a6-fb614500ad3b",
    "nome": "Biofísica"
  },
  {
    "id": "3510b1a5-f773-4ee9-a762-a5a83e6efb22",
    "nome": "Biologia Geral"
  },
  {
    "id": "959dd068-d2a5-4d56-b2df-d54fbd99944c",
    "nome": "Bioquímica"
  },
  {
    "id": "2dd0a41b-cb8e-44ca-8609-403fed4588b0",
    "nome": "Botânica"
  },
  {
    "id": "e509a09e-e571-4b74-b623-7ef1e3d0365d",
    "nome": "Ciência Política"
  },
  {
    "id": "a111a111-b222-c333-d444-e555e555e555",
    "nome": "Ciência da Computação"
  },
  {
    "id": "7f489104-f947-4652-b043-445106ac23e8",
    "nome": "Ciência da Informação"
  },
  {
    "id": "8c8c4b6c-7288-4f91-8a2a-638a8ba1cc24",
    "nome": "Ciência e Tecnologia de Alimentos"
  },
  {
    "id": "b498307a-8027-459d-831a-e1eeba03a0d3",
    "nome": "Comunicação"
  },
```

acadmap.me/api/programa/listar




```
[
  {
    "id": "e09c4859-7ca1-4349-a4a5-26de94ca2b91",
    "nome": "programa de pós graduação em ensino de biologia - profbio"
  },
  {
    "id": "cb125f9c-033c-4cee-adbf-1030836a088a",
    "nome": "programa de pós graduação em letras - profletras"
  },
  {
    "id": "ce377712-b007-4e50-ac09-710726cb9496",
    "nome": "programa de pós-graduação ciências do movimento humano - ppgcmh"
  },
  {
    "id": "362a880d-3450-4dfd-b897-9431418393c4",
    "nome": "programa de pós-graduação comunicação, cultura e amazônia - ppgcom"
  },
  {
    "id": "64d50698-a133-4e4d-b261-4b01f6c5c6d8",
    "nome": "programa de pós-graduação criatividade e inovação em metodologias de ensino superior - ppgcimes"
  },
  {
    "id": "3f12b21f-f4e5-4c3c-8d1f-facba16aae7f",
    "nome": "programa de pós-graduação economia aplicada - ppgea"
  },
  {
    "id": "d4041561-922f-4554-98fe-e6a34bcbef4c",
    "nome": "programa de pós-graduação educação escolar indígena - ppgeei(em associação: uepa sede - ufpa - ufopa - unifesspa)"
  },
  {
    "id": "6f5001d8-c139-420f-8bbd-b6f8695d8fb4",
    "nome": "programa de pós-graduação em administração - ppgad"
  },
  {
    "id": "e9a256c4-c17a-4d7e-ad15-057b03427180",
    "nome": "programa de pós-graduação em agriculturas amazônicas - ppgaa"
  },
  {
    "id": "363fd577-2117-45be-80c7-7295ea88f956",
    "nome": "programa de pós-graduação em antropologia - ppga"
  },
  {
    "id": "1cff6a0e-7684-4fc8-962f-3ad78fe60a7b",
    "nome": "programa de pós-graduação em análises clínicas - macpro"
  },
  {
    "id": "d72c623f-042e-4851-b268-ed56b0f51b7e",
    "nome": "programa de pós-graduação em arquitetura e urbanismo - ppgau"
  },
  {
    "id": "a19c4661-696f-4290-980e-44fa0fb46cb6",
    "nome": "programa de pós-graduação em artes - ppgartes"
  },
  {
    "id": "34dc8cba-af60-419b-b1c3-3c3571d3ead5",
    "nome": "programa de pós-graduação em assistência farmacêutica - ppgaf"
  },
  {
    "id": "a0643a35-6733-495b-8179-ba51f264c488",
    "nome": "programa de pós-graduação em atenção e estudo clínico no diabetes - ppgdiabetes"
  },
```


Diretórios sensíveis encontrados no arquivo index-DsIEw4jW.js não acessíveis via parâmetro URL:

- /api/log-erro/adicionar
- /api/log/adicionar
- /api/auth/refresh
- /api/usuario/cadastro
- /api/veiculo/periodico-pendente
- /api/veiculo/negar-veiculo/
- /api/veiculo/aprovar-veiculo/
- /api/log/historico
- /api/log-erro/historico
- /api/log-veiculo/historico

4.3 SSL/TLS & Headers

Descrição: Testar configuração do HTTPs e segurança do servidor

nmap –p 443 –script ssl-enum-ciphers acadmap.me

```
┌──(kali㉿kali)-[~/lab/acadmap.me/assets]
└─$ nmap -p 443 --script ssl-enum-ciphers acadmap.me

Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-03 15:24 EDT
Nmap scan report for acadmap.me (168.75.88.175)
Host is up (0.0070s latency).

PORT    STATE SERVICE
443/tcp open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
|       TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (secp256r1) - A
|     compressors:
|       NULL
|     cipher preference: client
|   TLSv1.3:
|     ciphers:
|       TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|       TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A
|     cipher preference: client
|_  least strength: A

Nmap done: 1 IP address (1 host up) scanned in 2.50 seconds
```

A análise do protocolo SSL/TLS demonstrou que o servidor está bem configurado, suportando apenas versões modernas e seguras (TLS 1.2 e 1.3), sem a presença de *ciphers* fracos como RC4 ou 3DES, e com compressão desativada, o que elimina a possibilidade de exploração de ataques como o **CRIME**. Esse resultado indica maturidade na configuração da camada de transporte, reduzindo significativamente a superfície de ataque relacionada a falhas criptográficas. Além disso, a ausência

de *cipher downgrade* evidencia que a aplicação não está suscetível a forçar o uso de protocolos obsoletos ou menos seguros, garantindo robustez frente a vetores comuns de exploração em ambientes web.

Do ponto de vista de riscos, não foram identificadas vulnerabilidades críticas nessa camada. O impacto de uma má configuração TLS seria alto, pois permitiria ataques de interceptação, vazamento de informações sensíveis e perda de confidencialidade em sessões autenticadas. Entretanto, a configuração encontrada mitiga esses riscos de forma eficaz.

Como recomendação, sugere-se a realização de auditorias periódicas com ferramentas de *hardening* TLS, uma vez que novas vulnerabilidades podem surgir em *ciphers* considerados seguros atualmente. Também é importante validar periodicamente os *headers* de segurança (como HSTS, X-Frame-Options e Content-Security-Policy), que têm papel essencial na proteção contra ataques de injeção de conteúdo e sequestro de sessão. Dessa forma, a aplicação garante não apenas a segurança do canal de comunicação, mas também a integridade e resiliência da camada de aplicação.

Resumo: Robusto contra ataques de cypher downgrade e maioria das vulnerabilidades conhecidas de SSL/TLS

Definição ataques tipo CRIME (Compression Ratio Info-leak Made Easy): explora compressão de dados em protoclos HTTPS ou TLS/SSL, reduzindo o tamanho dos dados transmitidos e o tamanho resultante vaza informações sobre o conteúdo secreto, como cookies de sessão.

Definição ataques Cypher Downgrade: força a comunicação HTTPS a usar uma versão mais fraca ou vulnerável de criptografia.

4.4 SQL Injection

Descrição: Injeção de código SQL malicioso na interface de login da aplicação.

sqlmap -u "https://acadmap.me/login" --data="username=admin&password=123" --risk=2 --level=2 --batch

Saída:



Os testes realizados com o **SQLMap** não identificaram parâmetros injetáveis na interface de login, sugerindo que a aplicação está bem protegida contra **SQL Injection** em seu fluxo principal de autenticação. Esse resultado é positivo, visto que essa vulnerabilidade está entre as mais exploradas em aplicações web e pode permitir desde o acesso não autorizado a dados sensíveis até o comprometimento total do banco de dados. O impacto potencial de um SQL Injection bem-sucedido seria crítico, podendo resultar em **vazamento de dados confidenciais**, **modificação ou exclusão de registros** e até mesmo na **execução de comandos no sistema operacional** caso o banco de dados fosse explorado em profundidade.

Apesar da ausência de vulnerabilidades em testes básicos e intermediários (níveis de risco 2 e nível de

profundidade 2), é importante destacar que isso não garante a total inexistência de falhas. Alguns vetores de ataque podem se manifestar em outros pontos da aplicação, como parâmetros em formulários secundários, URLs com query strings, APIs expostas ou até em funcionalidades administrativas menos utilizadas. Nesse sentido, o risco residual está associado à possibilidade de exploração de pontos ainda não testados ou falhas lógicas que não foram capturadas pelas injeções automáticas.